Informe Técnico de Auditoría: Reconocimiento y Gestión de Vulnerabilidades

Fecha de Emisión: 24 de febrero de 2026

Responsable: Ivan Escamez

Se ha llevado a cabo una auditoría de seguridad sobre el servidor DEBIAN identificado con la dirección IP 10.0.2.15. El proceso consistió en el descubrimiento de activos, identificación de servicios en red y un análisis de riesgos basado en vulnerabilidades conocidas (CVE). Se detectó un servicio crítico (Apache HTTP Server) cuya versión actual presenta fallos de seguridad documentados que comprometen la confidencialidad de los datos.

1. Metodología de Auditoría

El proceso se dividió en tres fases técnicas:

- Reconocimiento Activo: Uso de nmap para descubrimiento de puertos.
- Enumeración de Versiones: Identificación precisa de software y sistemas operativos.
- Investigación de Inteligencia de Amenazas: Correlación de versiones con bases de datos globales de vulnerabilidades (NVD/NIST).

3. Fase de Reconocimiento y Hallazgos Técnicos

3.1 Análisis de Puertos y Servicios (Nmap)

Se ejecutó un escaneo de huella digital del servicio mediante el comando: nmap -sV 10.0.2.15

Elemento Detalle Técnico, Dirección IP 10.0.2.15 “DEBIAN”

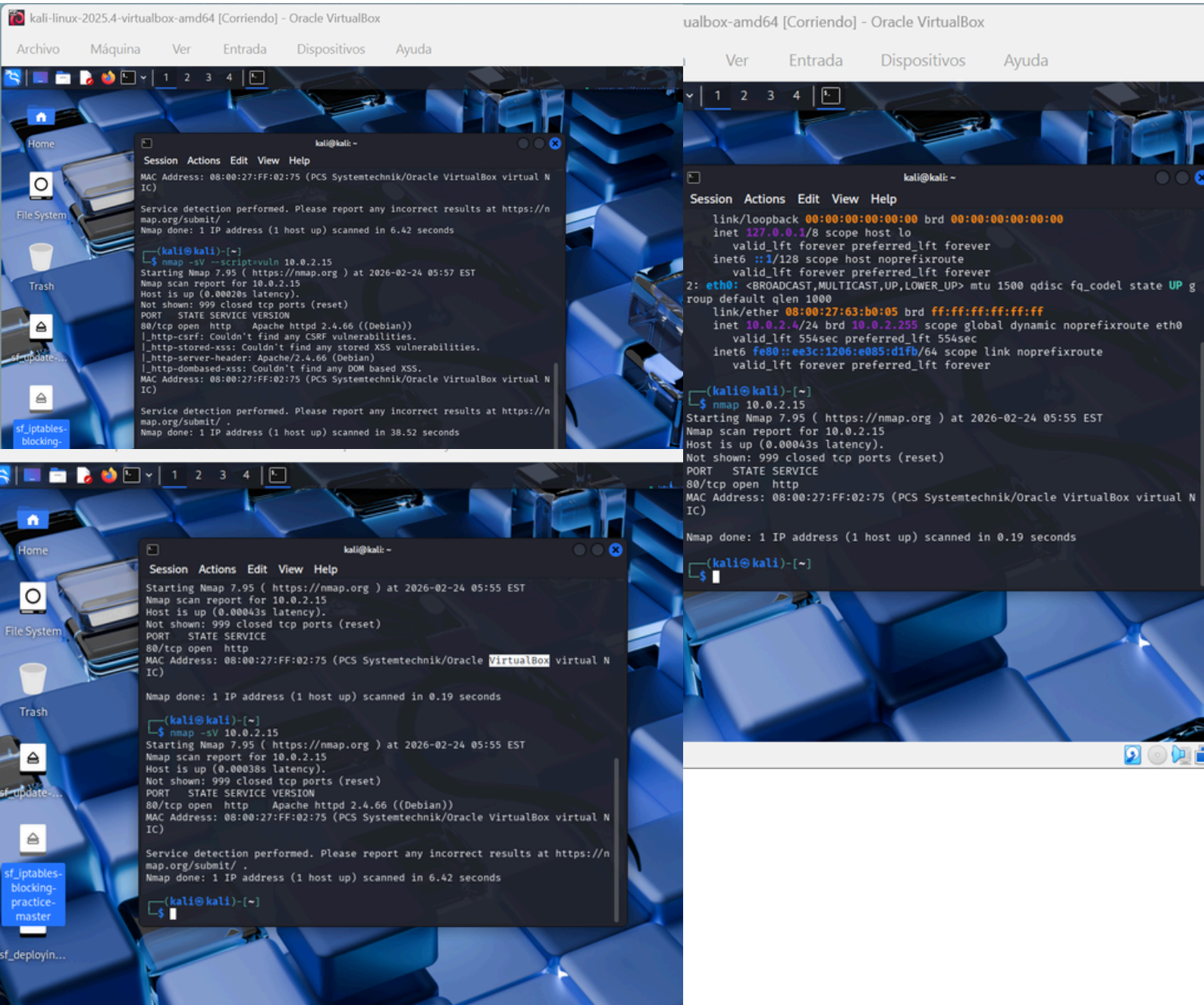
Puerto Abierto 80/tcp, Servicio http, Software Apache httpd 2.4.66

3.2 Escaneo de Vulnerabilidades por Script

Para profundizar en el análisis, se utilizó el motor de scripts de Nmap (NSE) con el fin de detectar debilidades obvias en la superficie de ataque:

nmap -sV --script=vuln 10.0.2.15

- Resultado del escaneo: El sistema confirmó que el servidor web Apache está operativo, pero los scripts automáticos no detectaron fallos de inyección inmediata o ataques de DoS genéricos, lo que obligó a realizar una investigación manual de la versión específica identificada.



4. Análisis Detallado de Vulnerabilidades (NVD)

Tras la fase de enumeración, se realizó una búsqueda exhaustiva en la National Vulnerability Database (NVD) del NIST para la versión Apache 2.4.66.

4.1 Vulnerabilidad Identificada: CVE-2024-40725

Se localizó una vulnerabilidad crítica de tipo Exposición de Código Fuente.

Descripción Técnica: El fallo se origina en una corrección parcial previa (CVE-2024-39884).

El motor de Apache ignora ciertas configuraciones heredadas de tipo de contenido (AddType), lo que provoca que archivos sensibles se entreguen como texto plano en lugar de ser interpretados por el servidor.

Análisis de Riesgo (CVSS 3.1):

Puntuación Base: 5.3 (MEDIUM).

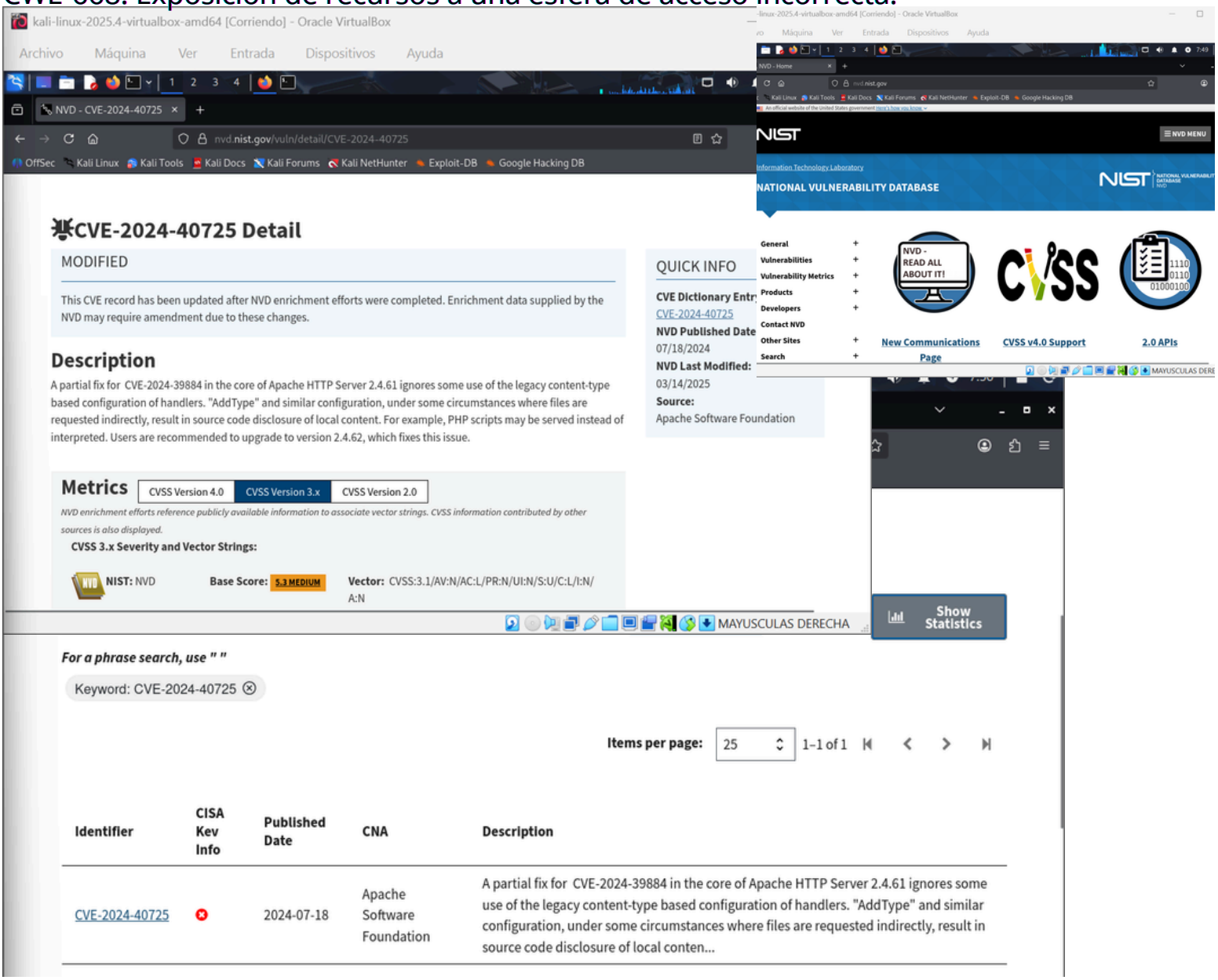
Vector: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N.

Interpretación: La vulnerabilidad es explotable de forma remota (Red), requiere poca complejidad técnica y no necesita interacción del usuario ni privilegios previos.

Impacto potencial:

Divulgación de Información: Acceso al código fuente de scripts PHP, revelando lógica de negocio y posiblemente credenciales hardcodeadas.

CWE-668: Exposición de recursos a una esfera de acceso incorrecta.



5. Plan de Mitigación y Recomendaciones

5.1 Acción Primaria (Actualización)

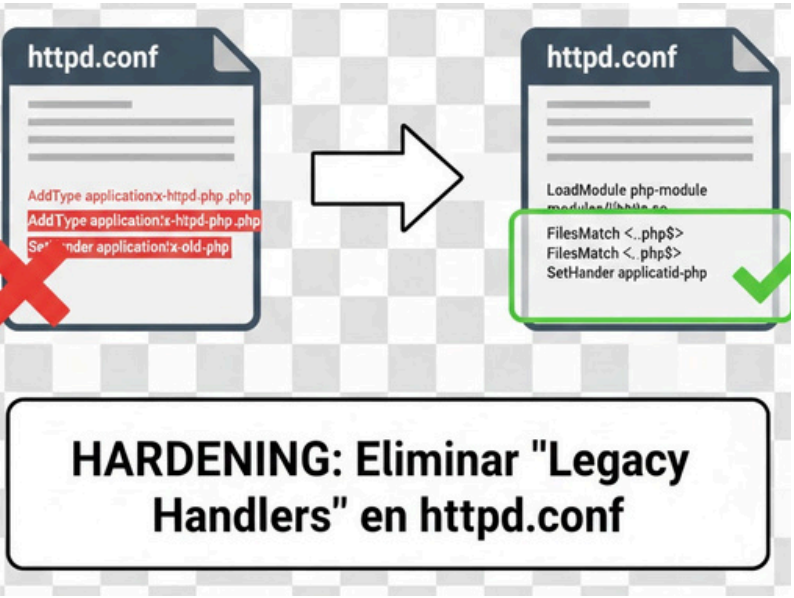
Se recomienda encarecidamente la actualización inmediata del servicio Apache HTTP Server a la versión 2.4.67 o superior. Esta versión incluye el parche oficial que corrige el manejo de las directivas de configuración de contenido.

5.2 Acciones Secundarias (Hardening)

Auditoría de Configuración: Revisar los archivos de configuración (httpd.conf) para eliminar el uso de manejadores de contenido antiguos (legacy handlers).

Mínimo Privilegio: Asegurar que el proceso del servidor web no se ejecute con privilegios de root, limitando el daño en caso de explotación.

Seguridad por Capas: Implementar un Web Application Firewall (WAF) que bloquee intentos de acceso a archivos sensibles.

6. Conclusión

La auditoría revela que, aunque el sistema está configurado correctamente en términos básicos, la falta
de actualización del software base (Apache) expone a la organización a riesgos de fuga de información. La aplicación de los parches recomendados neutralizará el vector de ataque identificado en este informe.